

Sentinel // SOC

Checklist de despliegue 24/7 — Tareas de Seguridad

Lo que te toca a ti (Arturo) para que el dashboard funcione con escaneos continuos en el servidor físico

Flujo objetivo: KALI escanea → genera alertas → BACKEND las guarda → DASHBOARD las muestra, corriendo 24/7. Los devs (Sixto, Tomás) dejan corriendo el backend y el frontend; tú dejas corriendo el Kali que los alimenta y audita que todo el conjunto sea seguro.



Nada de escaneos en producción sin la Autorización de Alcance firmada y la ventana coordinada con IT.

1. Prerequisitos (antes de tocar el server)

✓	Tarea	Responsable
☐	Autorización de Alcance firmada (Scope_Authorization_Form)	Tú + IT
☐	Definir los rangos/subredes/VLANs autorizados (scan_scope) y pasarlos a los devs	Tú
☐	Curar IOCs: ioc_hashes.txt, ioc_ips.txt, bad_domains.txt	Tú
☐	Definir el criterio de severidad (critical / medium / normal)	Tú
☐	Tener lista la imagen de Kali (creada desde la laptop)	Tú

2. Red — lo que hace que funcione 24/7 (y evita el problema de Docker)

✓	Tarea	Responsable
☐	VM Kali con red BRIDGED (External vSwitch) e IP real — no NATeada	Tú + IT
☐	La VM Kali alcanza las VLANs a escanear (VLAN IDs / puerto trunk)	IT
☐	IP estática para el Kali (para que backend y equipo lo encuentren)	Tú

3. Desplegar el Kali en el servidor

✓	Tarea	Responsable
☐	Importar la imagen como VM en el hipervisor	Tú + IT
☐	Primer arranque: regenerar llaves SSH y machine-id, hostname, IP	Tú
☐	Verificar herramientas (nmap/zmap/tshark) + cuentas admin/dev + SSH	Tú
☐	Cargar targets.conf con los rangos autorizados	Tú

4. Automatización 24/7 (tu parte clave)

✓	Tarea	Responsable
☐	Programar escaneos recurrentes (cron / systemd timers): descubrimiento + puertos	Tú

✓	Tarea	Responsable
☐	Programar escaneo de vulnerabilidades en la ventana coordinada con IT	Tú + IT
☐	login_monitor.py como servicio systemd (--follow) para logins en vivo	Tú
☐	Conectar la salida de los escaneos a la ingesta del backend (endpoint + token)	Con devs

5. Integración con el dashboard / backend

✓	Tarea	Responsable
☐	Prueba de punta a punta: escaneo real → alerta llega al dashboard en vivo	Con devs
☐	Verificar que severidad, IP, host y usuario se ven bien en el tablero	Tú

6. Seguridad / QA (esto solo lo piensas tú)

✓	Tarea	Responsable
☐	Probar la reja scan_scope: escanear fuera de alcance → debe rechazarse	Tú
☐	Auditar el firewall (solo 443 desde subredes internas / VPN)	Tú
☐	Confirmar acceso externo SOLO por VPN + HTTPS (Caddy) + MFA en SSH	Tú
☐	Gestión de accesos: cuentas admin/dev, llaves SSH, quién puede qué	Tú

7. Operación continua (una vez arriba)

✓	Tarea	Responsable
☐	Correr la Fase A (línea base) y producir el reporte de alcance	Tú
☐	Monitorear alertas a diario con el equipo	Tú + equipo
☐	Mantener los IOCs actualizados (threat intel)	Tú
☐	Vigilar la retención de la base (que no se llene) y los backups	Con devs
☐	Re-escaneos periódicos tras cada remediación	Tú

Criterio de "listo"

El despliegue está completo cuando: un escaneo programado corre solo en el Kali, sus alertas llegan al backend y se ven en el dashboard con la severidad correcta, la reja scan_scope rechaza lo no autorizado, y el acceso al sistema es solo por VPN con HTTPS. A partir de ahí, la operación es monitorear y mantener.